

API Security Risk Analysis Report

Future Interns

Cyber Security Task 03

Prepared By:

Vishwajeet Godse

API Tested:

JSONPlaceholder API

Date:

17 June 2026

Executive Summary

This report presents a security assessment of the JSONPlaceholder API. The assessment was conducted through documentation review and API testing using Postman. The objective was to identify common API security risks, evaluate authentication requirements, analyze exposed data, and review security-related response headers.

The assessment identified risks related to unauthenticated access, excessive data exposure, predictable resource identifiers, and missing recommended security headers.

Scope & Methodology

API Tested:

JSONPlaceholder

Base URL:

<https://jsonplaceholder.typicode.com>

Endpoints Tested:

GET /users

GET /posts

GET /comments

GET /users/1

GET /users/2

Tools Used:

- Postman
- Browser
- JSONPlaceholder Documentation

Methodology:

1. Documentation Review
2. Endpoint Testing
3. Authentication Analysis
4. Data Exposure Review
5. Header Inspection
6. Risk Classification

Finding 1: Unauthenticated Access

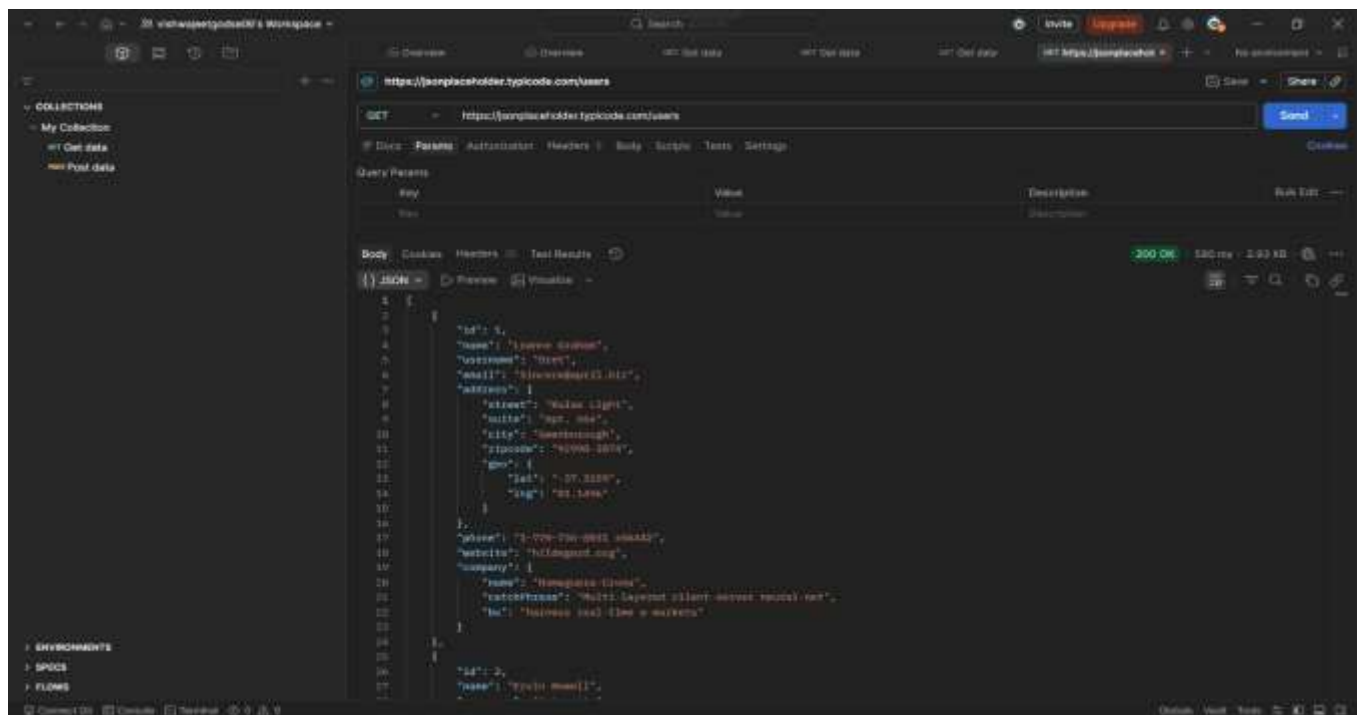
Description

During testing, the API endpoints were accessible without any authentication mechanism. Requests to /users, /posts, and /comments returned successful responses without requiring login credentials, API keys, or authentication tokens.

Evidence

The API returned a **200 OK** response when accessed without authentication.

Screenshot:



users_response.png

Severity

Medium

Business Impact

If a production API allows unauthenticated access, unauthorized users may be able to retrieve sensitive information. This increases the risk of data exposure and misuse of API resources.

Recommendation

Implement authentication mechanisms such as:

- API Keys
- JWT (JSON Web Tokens)
- OAuth 2.0

All sensitive endpoints should verify the identity of the requesting user before providing access.

Finding 2: Excessive Data Exposure

Description

The /users endpoint returns detailed user information including:

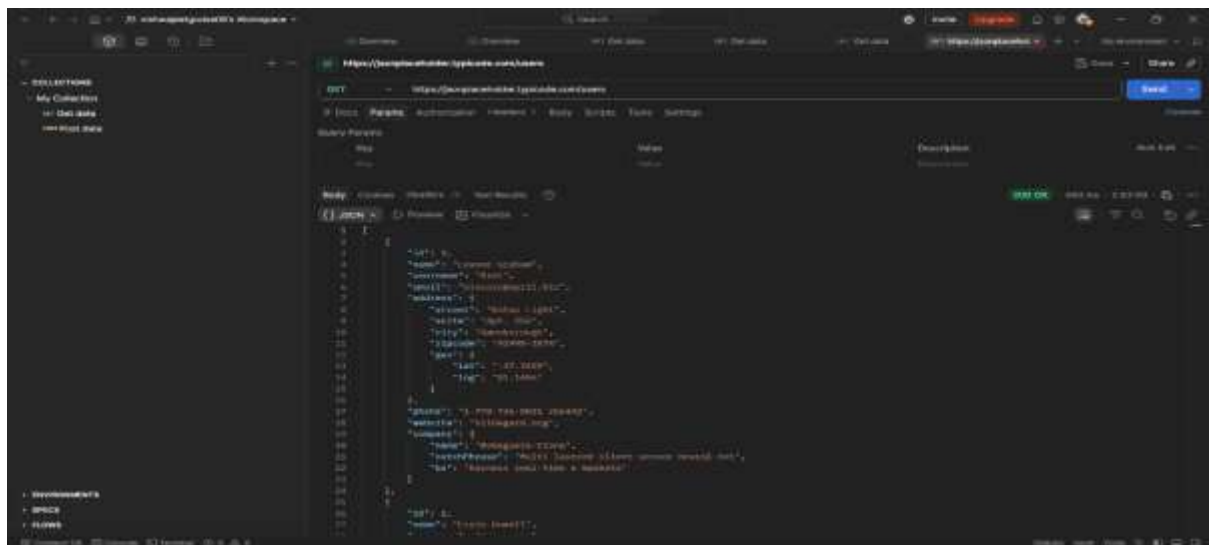
- Name
- Username
- Email Address
- Phone Number
- Address
- Website
- Company Information

Applications may not require all these fields for normal functionality.

Evidence

User records contained multiple personal and organizational data fields.

Screenshot:



users_response.png

Severity

Medium

Business Impact

Exposing unnecessary data increases privacy risks and may provide attackers with valuable information for social engineering or data collection activities.

Recommendation

Apply the principle of data minimization by returning only the information required by the application. Implement response filtering and role-based access controls where appropriate.

Finding 3: Predictable Resource Enumeration

Description

Individual user records were accessible using sequential numeric identifiers.

Examples:

`/users/1`

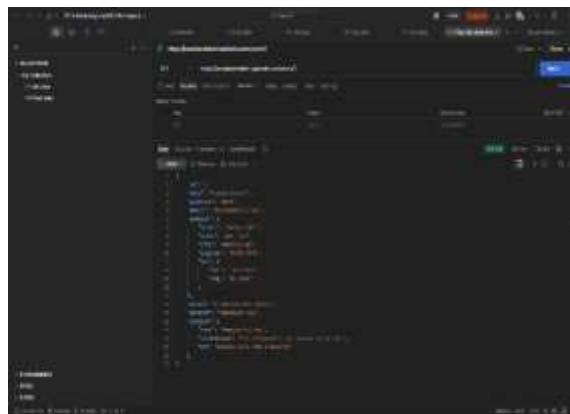
`/users/2`

The API allows direct access to resources by incrementing the identifier value.

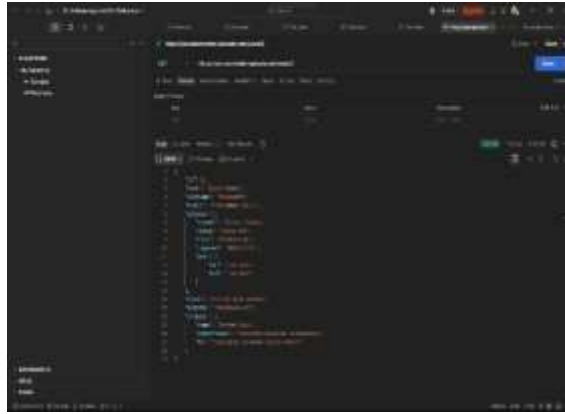
Evidence

Successful retrieval of different user records through sequential identifiers.

Screenshots:



user1_response.png



user2_response.png

Severity

Low-Medium

Business Impact

Predictable identifiers may allow attackers to automate the collection of user records and perform large-scale enumeration of available resources.

Recommendation

Implement authorization checks to ensure users can access only permitted resources. Consider using UUIDs or non-sequential identifiers to reduce predictability.

Finding 4: Missing Recommended Security Headers

Description

Header analysis identified that some recommended security headers were not present in API responses.

Present Header

X-Content-Type-Options: nosniff

Headers Not Observed

Content-Security-Policy (CSP)

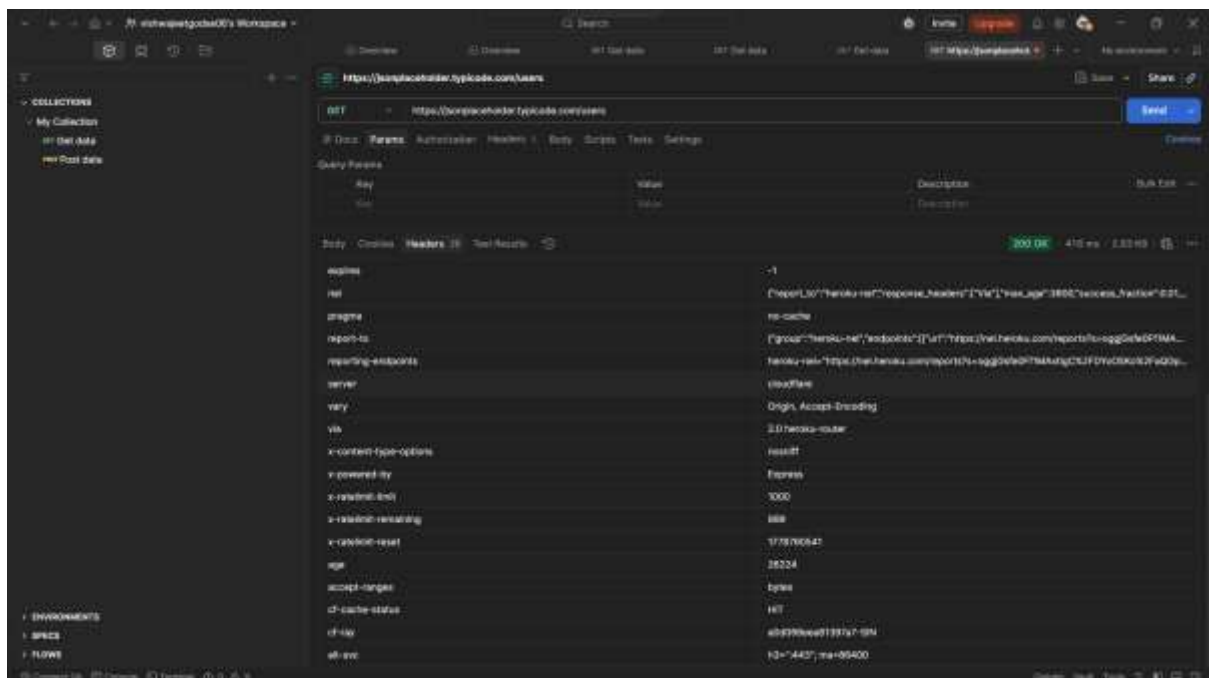
Strict-Transport-Security (HSTS)

X-Frame-Options

Evidence

Response header inspection performed using Postman.

Screenshot:



headers_analysis.png

Severity

Low

Business Impact

Missing security headers may reduce protection against browser-based attacks and weaken overall security posture when APIs are integrated with web applications.

Recommendation

Implement additional security headers, including:

- Content-Security-Policy (CSP)
- Strict-Transport-Security (HSTS)
- X-Frame-Options

These headers help strengthen client-side security and improve protection against common web-based threats.

Risk Summary Table

Finding ID	Finding	Severity
F-01	Unauthenticated Access	Medium
F-02	Excessive Data Exposure	Medium
F-03	Predictable Resource Enumeration	Low-Medium
F-04	Missing Recommended Security Headers	Low

Conclusion

The API Security Risk Analysis identified several common security concerns that would require attention in a production environment. While JSONPlaceholder is a public testing API, the findings demonstrate important API security concepts including authentication, data exposure, access control, and security header implementation. Addressing these issues would improve the overall security posture of a real-world API.